Ek Baithak · Data privacy & security note

Accel Business digital onboarding for MSMEs · built to the DPDP Act 2023 and DPDP Rules 2025 YTL Hackathon 2026 · Track A

Design rule: collect less, keep less, show everything. The DPDP Rules were notified on 13 Nov 2025; consent-manager rules apply from Nov 2026 and the core Data Fiduciary duties (notice, consent, security, breach reporting, retention, rights) from 13 May 2027. Ek Baithak meets those duties today, so Accel does not need to re-engineer later.

1. What we collect, why, and for how long

Data	Purpose (and only this purpose)	Legal basis	Retention
Business profile: type, city, size, needs	Recommend an eligible bundle and price	Consent (s.6)	90 days if no order; then deleted
GSTIN, legal name, address, constitution	Eligibility (GST-only products) and KYC	Legal obligation (DoT KYC)	Life of the connection + period set by the DoT licence
Document images (GST, Udyam, bill, ID)	Read fields once (OCR) and verify	Legal obligation	**Never stored.** Processed in memory and dropped; we keep verified fields + a SHA-256 hash
Entity Locker / registry records	Replace uploads with issuer-verified data	Consent (optional)	Reference (URI + hash) only, no copy
Signatory name, ID number	Telecom KYC and e-sign	Legal obligation	As KYC record; masked on every staff screen
Voice notes	Speech-to-text for the advisor	Consent	Audio dropped after transcription
Mobile / WhatsApp number	Order updates (so owners never have to call)	Consent (optional)	Until live + 90 days
Marketing preferences	New offers	Consent, **off by default**	Until withdrawn

2. Consent that people can actually read

- Notice shown **before** KYC, standalone (Rule 3), in the owner's language (10 Indian languages), one line per purpose.
- Required purposes (KYC, installation) are separated from optional ones (registry fetch, WhatsApp, marketing); nothing optional is pre-ticked except service updates the owner can switch off.
- Every consent gets a receipt ID + hash, versioned notice, timestamp and language. Format is ready for registered Consent Managers.
- **Withdraw as easily as you gave:** one tap in "My data", with the effect explained.

3. Data minimisation by design

- **Registry first, documents last:** a GSTIN pre-fills name, address and constitution; Entity Locker replaces the GST and Udyam uploads. Typical owner uploads drop from 4 to 1 (a recent bill), and identity is confirmed by Aadhaar OTP at signing instead of an ID photo.
- The advisor asks only for what changes the bundle (type, city, size, sites, needs). No date of birth, no PAN, no bank details.
- Partners see only the installation address, contact name and a masked phone number; their access ends 7 days after installation.
- Back-office and logs show masked identifiers (27PZ••••••••1ZH); full values only to the KYC role.

4. AI and third parties

- **OCR runs on our own server** (RapidOCR); documents are not sent to any AI service to be read.
- An AI "second reader" sees a document **only** when a hard check fails (e.g. GSTIN check digit) and is never the sole basis for a decision. Eligibility, price and KYC verdicts are plain code with tests (12/12 specimen applicants correct).
- Chat AI receives the conversation and catalogue, not documents. The prototype uses Gemini's free tier on synthetic data; production uses a paid, no-training enterprise tier in an Indian region, under a Data Processing Agreement.
- No data goes to model providers hosted outside approved regions.

5. Security controls

- TLS in transit; AES-256 at rest (prod); secrets in environment variables, never in code or logs.
- Role-based access: owner, partner, sales, KYC reviewer, auditor.
- **Tamper-evident audit log**: every access, consent, KYC decision and erasure is hash-chained and kept at least one year (Rule 6).
- Fraud defence: check digit, registry near-match finder (caught an altered GSTIN), two independent readers must agree before flagging tampering, human review for anything flagged.
- Breach response: contain, inform affected owners and the Data Protection Board without delay, detailed report within 72 hours.

6. Owner rights, built into the app

- "My data" shows everything held, why and until when; download as a file; correct details; erase (we explain what the telecom licence obliges us to keep); grievance answered well within the 90-day limit.